

CONTROLLO DEGLI ACCESSI AGLI OGGETTI PROTETTI

Gli individui autorizzati all'accesso nel sistema non hanno diritti omogenei per tutte le risorse

	File1	File2	File3	Printer	Disk
User1			Read	Write	Read
User2	Read Write	Execute		Write	Read Write

**Possibile meccanismo per restringere
il diritto di accesso a risorse specifiche**

Ci sono possibili svantaggi?

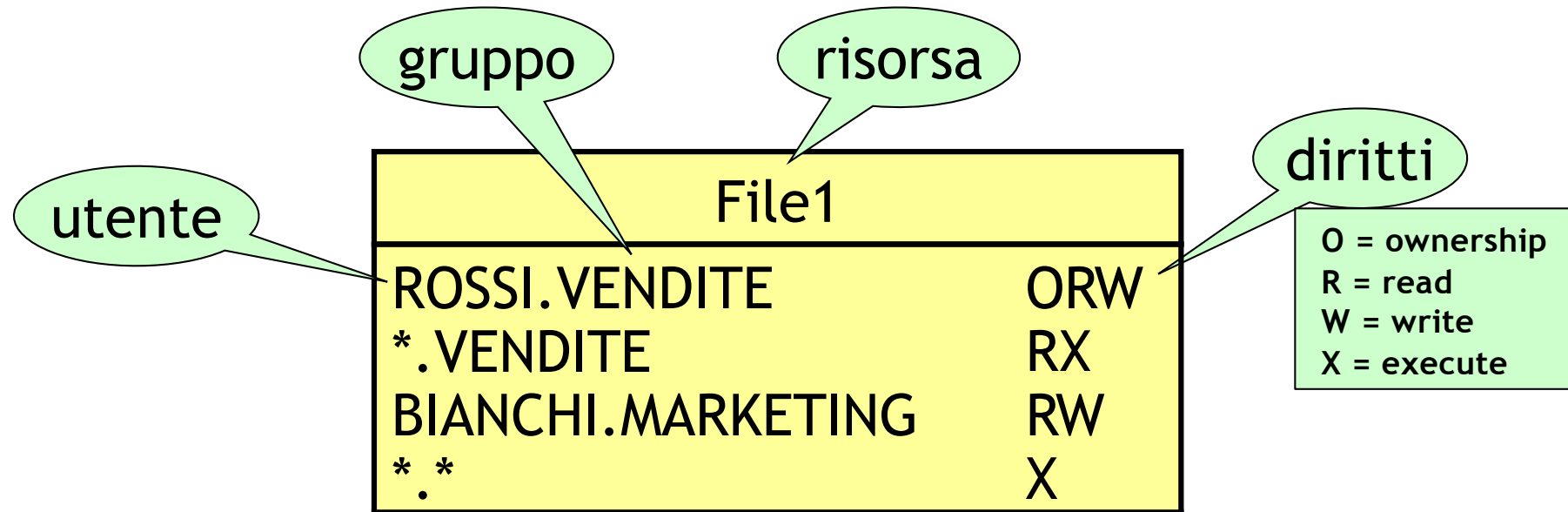
**Possibile meccanismo per restringere
il diritto di accesso a risorse specifiche, ma...**

poco raffinato

- distingue solo fra “possibilità” e “divieto” di accedere

poco usabile e flessibile

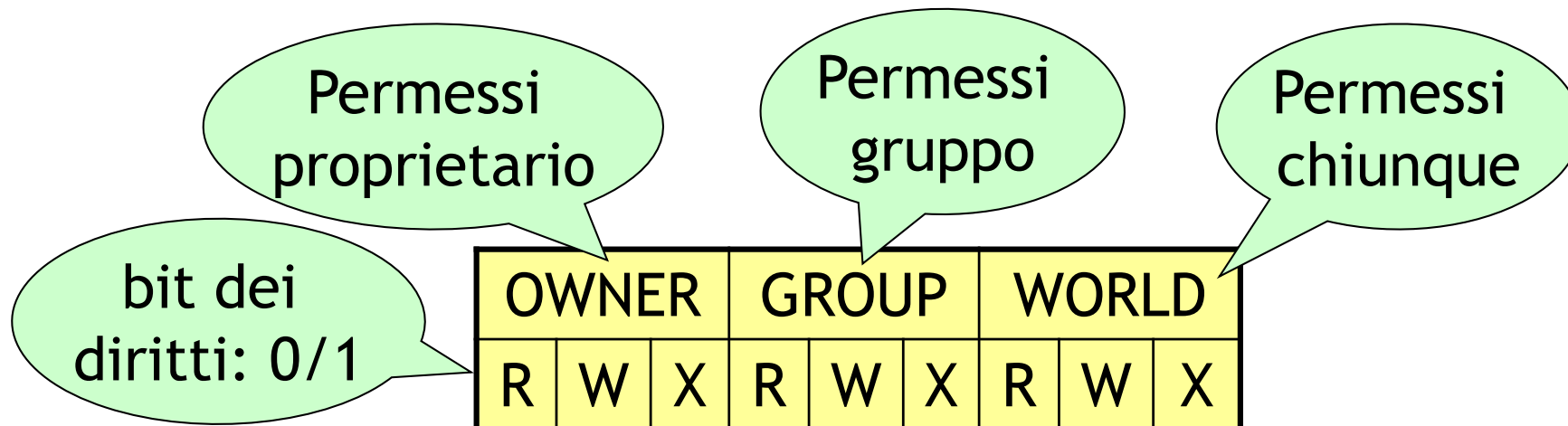
- difficile ricordare una password diversa per ogni risorsa
- difficile tenere traccia di chi ha accesso a risorse specifiche
- difficile gestire programmi che accedono a molte risorse
- difficile revocare i diritti



Benefici

- risparmio di spazio rispetto alla tabella completa
- facile determinare la lista degli utenti che hanno un diritto specifico su una risorsa condivisa
- facile revocare/modificare l'accesso di un utente a una risorsa

Versione semplificata di una Access Control List:
usa un numero fisso di bit per ogni file



Benefici

- occupazione memoria: solo ID user/group + 9 bit per file
- semplice da gestire: il proprietario assegna/modifica i diritti di ogni risorsa

- Mediazione completa: Controllare ogni accesso
 - ▶ Per esempio per prevenire attacchi TOC/TOU (time-of-check/time-of-use)
- Permettere di implementare il principio dei “privilegi minimi”
- Controllare l’uso appropriato degli oggetti protetti
 - ▶ anche evitando leak indiretti a soggetti non autorizzati

- Dati sensibili trasmessi su un canale alternativo, condiviso (anche legalmente) con un soggetto non autorizzato, in alcuni casi usando segnali “*non ovvi*”
- Esempi
 - ▶ Attaccante: utente interno malevolo o Trojan installato in un programma di servizio
 - ▶ Meccanismi
 - Scrivendo i dati su altri file con diversa protezione
 - Codificando informazioni nei nomi dei file
 - Codifica segreta in file legali: numero di spazi dopo ‘:’, ultima cifra non significativa di un campo, ...
 - Segnalando eventi che possono essere monitorati
 - Sfruttando la presenza/assenza di oggetti in memoria, il blocco/sblocco di un file in un intervallo di tempo concordato, ...

Discretionary Access Control (DAC) (p.e. access control list)

Il proprietario di una risorsa può concedere/modificare
l'accesso e i diritti ad altri a sua discrezione

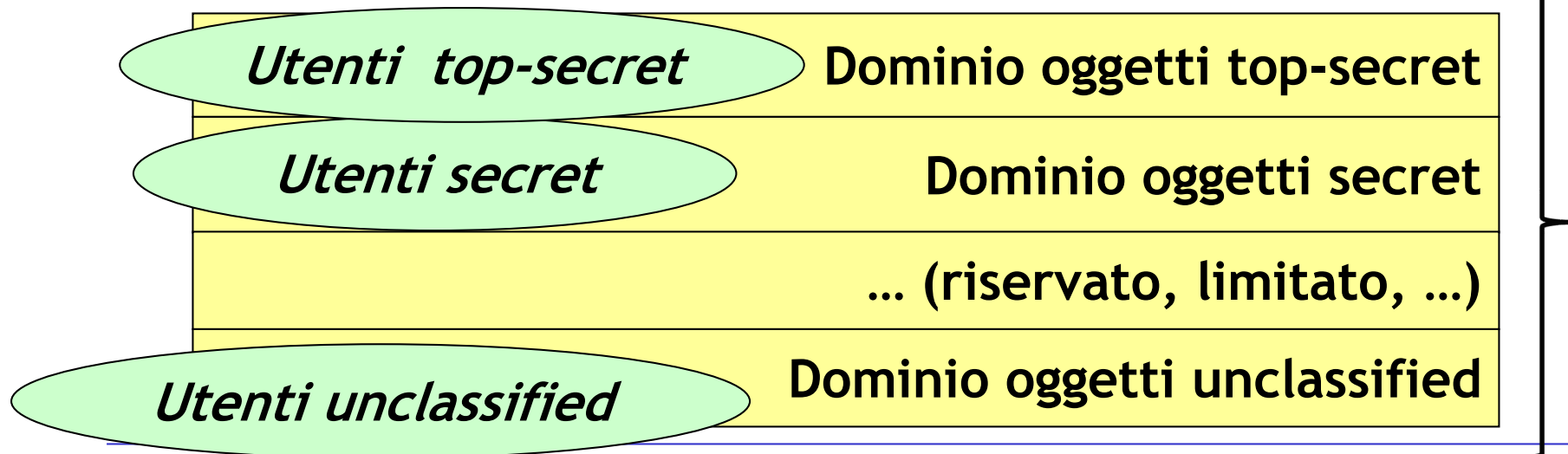
Mandatory Access Control (MAC)

Il sistema impone un modello che limita e controlla la
discrezionalità degli utenti nell'assegnare i diritti
di accesso alle risorse

- Definiscono in maniera precisa la relazione di accessibilità fra soggetti e oggetti del sistema
- In base a obiettivi e requisiti di sicurezza specifici, fortemente dipendenti dal dominio applicativo
- Primo esempio: Sicurezza multi-livello (nasce in ambienti militari)
 - la confidenzialità dei dati è spesso il requisito principale
 - Può essere adattato per ambienti commerciali: La confidenzialità è ancora un requisito importante, ma l'integrità dei dati può essere in alcuni casi più importante della confidenzialità degli stessi

- Origine: Policy sicurezza militare
 - Classifica i livelli di sicurezza per soggetti e oggetti

Accesso consentito solo se:
livello soggetto $\geq$ livello oggetto



Principio

Se un soggetto rilascia un oggetto sensibile, bisogna gestire opportunamente i casi in cui la risorsa viene acquisita da un altro soggetto.

Definizioni

Soggetti (elementi attivi):

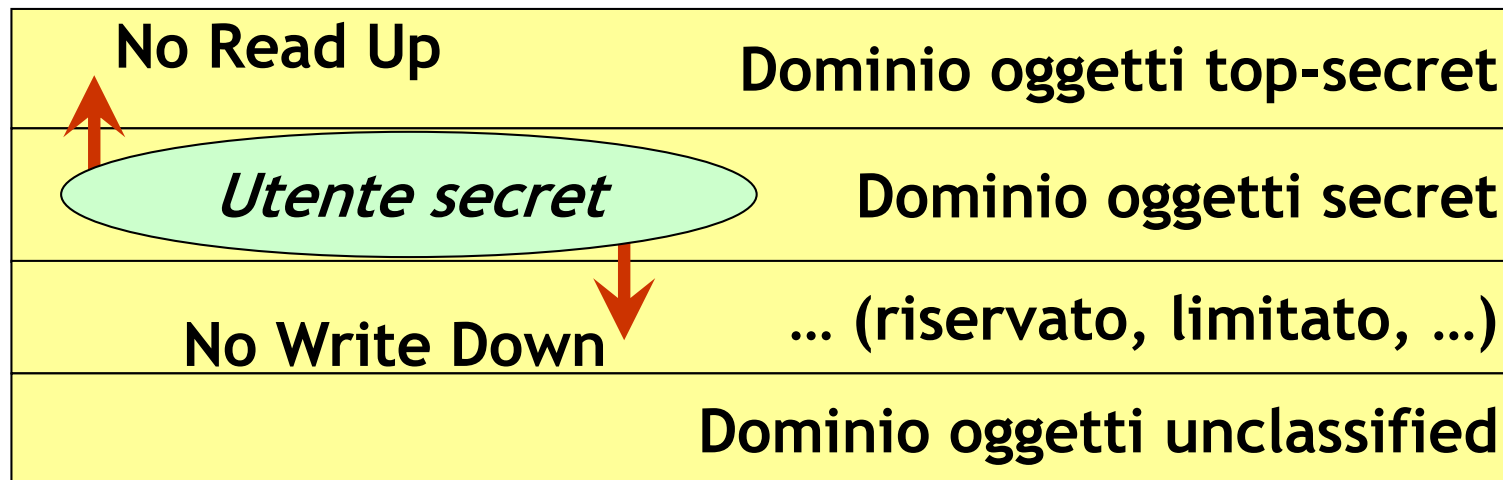
utenti, processi, ecc.

Oggetti (risorse contenenti dati sensibili):

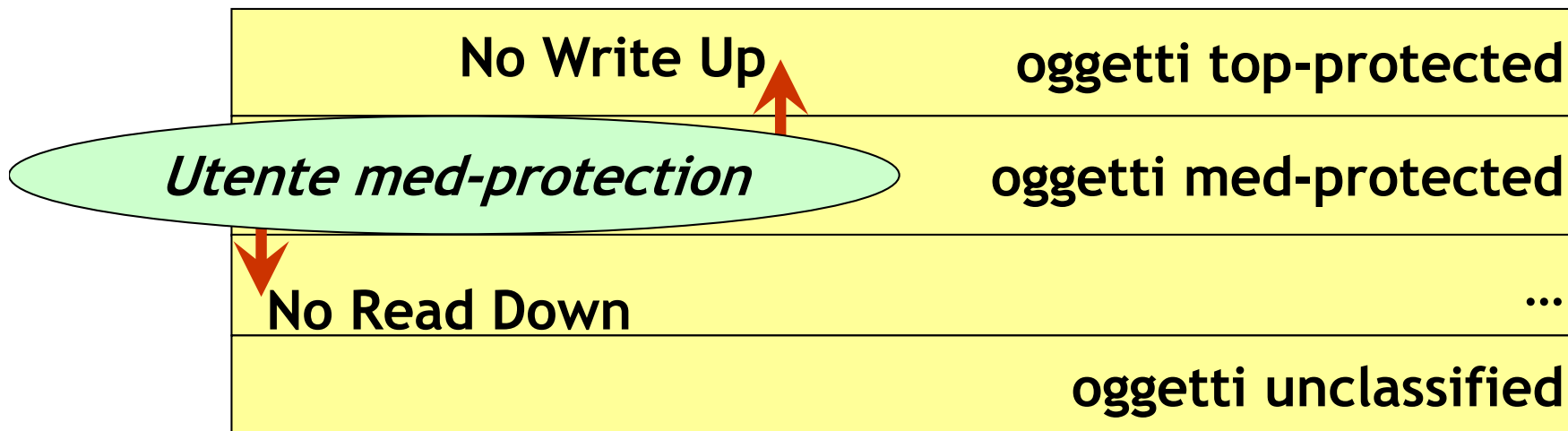
file, memoria, ecc.

Modello di Bell-LaPadula (orientato alla confidenzialità)

- Il sistema operativo usa uno schema di controllo accessi di tipo MAC che garantisce 2 proprietà
 - ▶ Simple security property (no-read-up)
un soggetto non legge oggetti di classificazione più alta
 - ▶ Confinement property (no-write-down)
un soggetto non scrive oggetti di classificazione più bassa



- Il sistema operativo usa uno schema di controllo accessi di tipo MAC che garantisce 2 proprietà
 - ▶ Simple integrity axiom (no-write-up)
un soggetto non può modificare oggetti di classificazione più alta
 - ▶ Integrity confinement axiom (no-read-down)
un soggetto non legge oggetti di classificazione più bassa



- Complessità di amministrazione
- Necessità di implementare applicazioni dedicate
- Tendenza a forzare “over-classification” delle informazioni
- Problema del “blind write-up” (senza acknowledgement)
- Definire molti livelli di classificazione dei dati può portare a modelli complicati
- ...

“A livello di competenze di sicurezza informatica, è importante conoscere gli obiettivi e il funzionamento dei modelli multi-livello per saper meglio comprendere e analizzare i problemi che devono essere affrontati, e sapere meglio progettare/valutare i possibili approcci”

- Multi-level security models: flussi di informazione controllati in base al livello di criticità dei dati (e degli utenti)
- **Multi-lateral security models:** flussi di informazione controllati in base a raggruppamenti semantici dei dati (e degli utenti)
 - ▶ **Compartimenti, Progetti, Gruppi, Ruoli, ...**

- Origine: Policy sicurezza militare
 - ▶ Classifica i livelli di sicurezza per soggetti e oggetti
 - ▶ Associa le informazioni e i soggetti a “compartimenti”
compartimento = progetto/missione/...
 - ▶ Regola della **necessità di conoscere**:

Accesso consentito solo se:
 livello soggetto $\geq$ livello oggetto **AND**
 compartimenti oggetto $\subseteq$ compartimenti soggetto

	Dominio oggetti top-secret
<i>Utente secret</i>	Dominio oggetti secret
	... (riservato, limitato, ...)
	Dominio oggetti unclassified

- Obiettivo: Gestione dei conflitti di interesse (COI)
 - ▶ Ovvero: controllare il flusso di dati critici tra aziende concorrenti, limitando l'accesso alle informazioni riservate di una data compagnia da parte di consulenti
- Politica di accesso
 - ▶ Organizzazione dei dati a tre livelli
 - Oggetti singoli
 - inclusi in -
 - Dataset aziendali (ogni oggetto in un unico dataset)
 - inclusi in -
 - Classi di COI fra dataset (ogni dataset in un'unica classe)
 - ▶ Regola di accesso per un soggetto S e un oggetto O
$$\text{dataset}(O) = \text{dataset}(O') \text{ OR } \text{dataset}(O) \notin \text{COI}(\text{dataset}(O'))$$
dove O' è un qualsiasi oggetto che S ha già acceduto

Dati che il S.O può tracciare

- lettura e scrittura di dati: accesso a file, memoria, ecc.
- creazione o distruzione di un oggetto
- accesso degli utenti al sistema: login e logout
- operazioni amministrative: creazioni di utenti, ecc.
- operazioni in modalità privilegiata
- operazioni non usuali
- ...

INTRUSION DETECTION SYSTEMS

Sistemi (automatici e non) che analizzano i dati tracciati (auditing trails) per determinare/prevenire tentativi di compromissione o di uso non autorizzato di un sistema

- **Minimi privilegi**
- **Mediazione completa**
- **Autorizzazione negata per default**
- **Multiple point of failure**
- Separazione fra utenti, Minima condivisione
- Protezione rispetto al riutilizzo delle risorse
- Accounting and audit

Ma in considerazione dei requisiti di usabilità

- Economia del meccanismo
- Struttura aperta
(basata sulla segretezza di pochi elementi critici)
- Facilità di uso

- Autenticazione
 - ▶ Identificazione sicura degli utenti autorizzati all'accesso
- Controllo degli accessi
 - ▶ Restrizione e controllo dei diritti di accesso alle risorse
- Modelli di sicurezza
 - ▶ Definizione dei requisiti e delle politiche di sicurezza in base alle quali governare il controllo degli accessi
- Auditing
 - ▶ Monitoraggio delle azioni degli utenti, per scoprire possibili/potenziati intrusioni nel sistema o violazioni delle politiche di sicurezza